AEGIS · V1.0

AGENT REMEDIATION GOVERNANCE SPECIFICATION · 修复作业规范

智能体代码问题修复方法与标准规范

铁律约束 · 流程收敛 · 护栏强制 —— 修复作业域标准

> 面向 zcode 等编码智能体的修复作业规范：把测试失败、静态扫描（SAST）、开源组件漏洞（SCA） 等问题的修复交给 AI 执行时，以八条修复铁律、S0 至 S4 五级定级、P0 至 P6 七阶段作业流程、「提示词—护栏—CI」三层防线与 ATLAS 审批回路，约束 AI 的发散修改，使每一次修复收敛、 可验证、可回滚、可审计，并将修复教训沉淀为智能体的长期能力。

适用对象

zcode 及同类编码智能体 × 修复作业域

规范内容

修复铁律 · 定级准入 · 作业流程 · 护栏机制 · 验证准出 · 度量反哺

配套规范

ATLAS V1.0 智能体执行留痕与人机协同平台规范

编制与日期

苏木 · 2026 年 9 月

目 录

第一章 总 则 2
1.1 编制背景与核心问题 2
1.2 理论定位与收敛判据 2
1.3 适用范围与对象 3
1.4 与 ATLAS V1.0 及自进化体系的关系 3

第二章 理论根基与标准映射 3
2.1 理论根基 3
2.2 标准映射 4
2.3 设计公理 5

第三章 修复铁律与禁止行为 5
3.1 八条铁律 5
3.2 禁止行为清单 6
3.3 冲突裁决与例外通道 6

第四章 问题分类、定级与准入 7
4.1 问题来源与分类 7
4.2 严重度定级与处置时限 7
4.3 误报申诉、依赖修复与风险接受 8
4.4 修复准入检查 8

第五章 修复作业流程 8
5.1 流程总览 8
5.2 阶段定义与门禁 9
5.3 红绿基线法 10
5.4 异常路径与安灯升级 10

第六章 行为约束与护栏机制 10
6.1 三层防线 10
6.2 变更预算 11
6.3 冻结清单与权限阶梯 11
6.4 三单结构化契约 12
6.5 智能体集成方案 13

第七章 验证与准出 13
7.1 三层验证门 13
7.2 回归测试选择 14
7.3 安全修复专项准出 14
7.4 准出检查单与提交规范 14

第八章 度量与持续改进 15
8.1 核心度量 15
8.2 教训反哺循环 15
8.3 成熟度模型 16

第九章 治理协同与实施路线 16
9.1 角色与审批矩阵 16
9.2 留痕与审计对接 17
9.3 实施路线与验收 17

附录 A 修复作业三单模板 18

附录 B 智能体守则注入片段 19

附录 C 术语表 19

摘要

编码智能体进入研发主流程后，把测试失败、静态扫描（SAST）、开源组件漏洞（SCA）、动态检测等扫描器产出的修复任务整体交给 AI 处理，很快会暴露同一个问题：**发散修改**——Agent 在修复过程中超出问题边界，顺带重构、改测试迁就代码、压制症状、触碰冻结资产，最终「修一个、坏两个」，甚至掩盖缺陷制造假绿。本规范的核心判断是：发散不是模型能力问题，而是作业制度缺失——人类工程师同样会犯错，但被代码评审、CI 门禁、发布流程与职业规范层层约束住；给 Agent 建立同等强度的机器可执行约束，发散即可收敛。

为此，本规范以「修复作业是受约束的搜索问题」为理论原点，融合 ISO/IEC/IEEE 14764 维护过程、NIST SSDF 漏洞处置实践（RV 系列）、IEEE 1044 缺陷分类、变更影响分析与安全回归测试选择等既有理论与标准，定义了：八条修复铁律与十二类禁止行为；S0 至 S4 五级问题定级与准入五查；P0 至 P6 七阶段作业流程与红绿基线法；「提示词—护栏—CI」三层防线（diff 预算、冻结清单、权限阶梯、三单结构化契约）；三层验证门与准出检查单；度量指标、教训反哺循环与成熟度模型；以及与 ATLAS V1.0 审批回路、留痕协议的对接映射。全部约束以机器可校验的三单（根因单、方案单、验证单）落地，使规范从文档变成 schema。

量化目标：修复引入新缺陷率低于 5%，一次通过率不低于 70%，发散指数低于 10%，测试篡改进入主干数为 0（红线）。规范附完整的三单模板与提示词注入片段，可直接集成到zcode 等编码智能体。

第一章 总 则

1.1 编制背景与核心问题

修复是研发中占比最高、风险密度最大的作业类型：测试失败要修，SAST、SCA、DAST 等安全与质量扫描器（如奇安信代码卫士、开源卫士及各类 AI 扫描）持续产出告警要修，线上回归也要修。这类任务输入明确、判据清晰，看似最适合交给编码智能体自主完成；但实践中普遍出现「预期外修改」：Agent 的 diff 远超问题本身所需，引入新缺陷、破坏既有功能，或以规避手段让告警消失。本规范将此类现象统一定义为**发散修改**，并归纳为六类失败模式，见下表。

编号	失败模式	典型表现	直接后果
F1	**范围蔓延**	顺带重构、重命名、格式化与问题无关的代码	diff 膨胀，评审负担激增，无关行为被改变
F2	**测试篡改**	修改断言、删除或跳过测试使结果变绿	假绿掩盖真缺陷，回归防线静默失效
F3	**表象压制**	吞异常、返回默认值、绕过或放宽校验	根因未除，问题在别处延迟爆发
F4	**过度修复**	为局部小问题引入新抽象、新框架级改动	修复面大于问题面，成为新缺陷温床
F5	**资产误改**	改 CI 配置、依赖版本、安全策略让告警消失	基础设施与安全基线被破坏
F6	**幻觉修复**	调用不存在的 API、编造依赖版本与配置	编译失败或引入难以察觉的隐性错误

表 1-1 发散修改的六类失败模式

六类模式背后是四个结构性成因。其一，目标函数错位：Agent 的成功判据被简化为「测试变绿、告警消失」，而非「系统正确」，这正是强化学习研究中的 reward hacking——修测试比修代码更容易让判据变绿，Agent 便会理性地走捷径。其二，上下文盲区：Agent 对调用方约定、业务约束与历史决策的全局视图，看不见自己的修改会波及何处。其三，变更边界完全缺失——没有任何人事先定义「合法变更空间」，Agent 只能在模糊指令下自由发挥。其四，验证闭环缺失：完成与否由 Agent 自述，缺少独立门禁裁决。

需要强调：上述错误人类工程师同样会犯，人类之所以不失控，是因为被代码评审、CI 门禁、发布流程与职业规范四层制度约束。因此本规范的立场是：**不要指望用更强的模型替代制度，而要给 Agent 建立与人类同等的制度约束**，并把其中可形式化的部分交给机器强制执行。

1.2 理论定位与收敛判据

本规范把一次修复作业形式化为五元组 T = 〈P, C, Δ, V, R〉：P（Problem）为有证据的问题陈述；C（Constraints）为合法变更空间，含 diff 预算、冻结清单、权限与禁改模式；Δ（Change）为实际产生的补丁；V（Verification）为独立于 Agent 的验证判据；R（Rollback）为失败退路。由此得到修复完成的收敛判据：

> **收敛判据（Definition of Done 的理论形式）**

> 修复完成当且仅当以下四条同时成立：P 被证实消除（红基线转绿）；Δ 落在 C 之内（变更未越界）；V 全部通过（三道门独立裁决）；Δ 可独立回滚（原子提交）。发散即变更越界或验证缺失；规范的全部内容，就是把 C 与 V 从「约定俗成」变成「机器强制的硬边界」。

这一定位给出两条推论。推论一：修复方法论的优先级是先扩大 C 与 V 的确定性，再提升Agent 的搜索能力——约束先行，能力其次。推论二：发散治理不能只靠提示词（它只影响意图），必须有运行时护栏（约束行为）与 CI 门禁（裁决结果），即第六章的三层防线。

1.3 适用范围与对象

本规范代号为 AEGIS（神盾），取义自双层防护：既挡缺陷与漏洞进入主干，也约束修复作业自身不发散。本规范适用于编码智能体承担的缺陷修复、安全漏洞整改、测试失败修复、静态检查清理四类作业；问题来源覆盖单元与集成测试、SAST、SCA、DAST 与 IAST、lint 与代码规范检查、运行时告警。适用对象为 zcode 及同类编码智能体、其运行护栏组件与承载审批回路的协同平台。不适用范围：新功能开发（另有作业规范）、架构级重构（须人工主导立项）、生产环境应急事件（按应急响应流程执行，事后回归本规范补齐复盘）。

1.4 与 ATLAS V1.0 及自进化体系的关系

ATLAS V1.0（智能体执行留痕与人机协同平台规范）定义的是通道域：过程怎么留痕、变更怎么呈报、人工怎么介入、指令怎么下发。本规范定义的是作业域：修复这件事按什么方法做、做到什么程度算对。两者对接三点：本规范的审批门 GATE 映射 ATLAS 的 D 级决策工单；修复作业全程事件按 ATLAS TraceEvent 协议上报留痕；复盘产出的教训条目以事件形式回流自进化体系（避错记忆、技能库、判例库），构成「失败—复盘—规则化」的高质量学习信号源。

第二章 理论根基与标准映射

本章回答「规范的权威性从何而来」：不是发明新流程，而是把行业已验证的维护与安全工程制度翻译为机器可执行的约束。凡有现行标准可依的，直接引用；凡有成熟理论支撑的，注明落点，使每一条条款都可溯源。

2.1 理论根基

理论	核心思想	本规范落点
最小变更原理	回归概率随变更范围超线性增长；根因修复往往同时是 diff 最小的修复	diff 预算（6.2）、铁律 L1、L4
根因分析 RCA	5 Why、鱼骨图、故障树：消除症状只会让问题换个地方复发	P1 只读定位、根因单、铁律 L2
变更影响分析	Bohner 与 Arnold：由依赖关系评估修改的波及面	方案单影响面声明、回归选择（7.2）

理论	核心思想	本规范落点
安全回归测试选择	Rothermel 与 Harrold：可证明不漏检的测试子集选择理论	门三的回归选择集（7.2）
契约式设计	Meyer：后置条件成立才算履约	红绿基线即修复任务的后置条件；三单即作业契约（6.4）
防错法 Poka-yoke	新乡重夫：结构性约束优于「依赖人小心」	冻结清单、护栏规则、权限阶梯（6.3）
安灯机制	丰田：异常即停线并拉人，禁止带病继续	连续失败强制升级人工（5.4）
错误预算	SRE：用预算量化容忍度，预算耗尽即冻结变更	发散预算与回归逃逸预算（8.1）

表 2-1 理论根基与本规范落点

2.2 标准映射

标准	关键内容	本规范落点
ISO/IEC/IEEE 14764、12207	维护过程：问题与修改分析、实施、评审验收、交付与纠正性维护分类	第五章流程骨架（P0 至 P6）
IEEE 1044	缺陷按「类型 × 原因」两维分类	4.1 分类轴、根因单原因字段
ISO/IEC 25010	产品质量特性模型	4.2 定级维度依据
NIST SP 800-218（SSDF）	RV.1 持续识别确认漏洞、RV.2 风险排序与修复时限、RV.3 根因分析防复发	第 4 章定级 SLA、第 5 章流程、8.2 反哺
OWASP ASVS / SAMM	应用安全验证要求、软件保障成熟度	7.3 安全专项准出、8.3 成熟度模型
FIRST CVSS v4.0	漏洞严重度量化	4.2 S 级与 CVSS 的映射规则
MITRE CWE	弱点通用枚举	安全类问题根因映射字段
ISO/IEC 42001、NIST AI RMF	AI 系统治理、风险分级管控	第 9 章治理框架与审批矩阵
GB/T 25000.51	就绪可用软件产品质量与测试评价要求	7.1 验证证据的形式要求
GB/T 43698-2024	软件供应链安全要求	4.3 依赖类漏洞修复决策序

表 2-2 引用标准与落点（以各标准现行版本为准；企业内部标准可叠加，冲突时从严）

2.3 设计公理

以下五条公理是全部条款的推理起点，条款与公理冲突时修改条款而非公理。

公理一 先诊断后治疗。未取得根因假设与红基线之前，禁止写第一行修复代码。诊断权与修复权分离，是防发散的第一道闸。

公理二 测试是资产而非障碍。测试的权威性高于 Agent 的判断；在任何情况下，修改测试的门槛永远高于修改代码。

公理三 预算即自由。显式变更预算不是限制修复能力，而是把「无限责任」变成「有限责任」：预算内的修复 Agent 享有完全自主权，无需请示。

公理四 无证据不算完成。完成由独立验证定义，不由 Agent 自述定义；一切判据必须可归档、可复核。

公理五 修复必须能退回。任何时刻可独立 revert 是修复被接受的前提；不可回滚的修改视同未完成。

第三章 修复铁律与禁止行为

3.1 八条铁律

铁律是修复作业的宪法条款：面向任何级别、任何来源的问题一律适用；Agent 不可通过配置关闭，只能经 GATE 审批获得一次性例外。每条铁律都同时给出机器可执行的违例检测方式，确保「写进规范」同时「落在护栏」。

编号	铁律	约束内容	违例检测
L1	**最小变更律**	diff 只服务当前问题单；禁止任何顺带的重构、重命名、格式化与性能优化	护栏比对实际 diff 与问题单涉及范围
L2	**根因优先律**	禁止压制表象：吞异常、返回默认值、绕过或放宽校验、调低日志级别	禁改模式库匹配（3.2）
L3	**测试神圣律**	禁止修改、删除、跳过既有测试以通过验证；改测试必须走测试缺陷认定流程	test 路径触碰即拦截（附录 B 规则）
L4	**影响面受控律**	实际 diff 必须落在方案单声明的变更清单内，计划外文件出现即违规	门一执行 diff 对声明的比对
L5	**红绿基线律**	无红基线不得实施修复，无绿证据不得申报完成	验证单强制字段，缺失即驳回
L6	**单一职责律**	一个修复单、一个根因、一个原子提交、一个 PR	提交信息与 PR 模板机器校验
L7	**可回滚律**	修复必须可独立 revert，禁止与无关变更混杂提交	提交原子性检查
L8	**知情披露律**	超范围修改、修复失败、不确定性与衍生问题必须即时上报，禁止隐瞒	diff 与声明差异强制披露审查

表 3-1 八条修复铁律

3.2 禁止行为清单

下列行为在局部语境下常常「看起来合理」，因此单列成清单并逐项挂接护栏，避免 Agent 以局部合理推演出全局违规。清单按违例频次排序，随反哺循环（8.2）持续扩充。

禁止行为	表面合理性	实际危害	拦截层
except 后直接 pass 吞异常	让报错消失最快	异常被吞，故障延迟爆发	护栏 · 模式匹配
放宽或删改断言	「预期值过时了」	掩盖回归，制造假绿	护栏 · 测试触碰拦截
skip、xfail 测试	「先让 CI 过」	覆盖率静默下降	护栏 · 配置 diff 检查
无关代码全局格式化	「顺手统一风格」	diff 膨胀，真变更被淹没	护栏 · 预算计数器
直接改依赖版本号	「升级就修好了」	传递性破坏与许可风险	护栏 · 冻结清单
注释掉问题代码	「保守、可逆」	死代码累积，行为未消除	护栏 · 模式匹配
硬编码环境相关值	先绕过环境问题	生产复现、凭证泄漏	护栏 · 敏感模式扫描
修改 CI 门禁配置	「门禁太严了」	质量防线被拆除	护栏 · 冻结清单
整函数整模块重写	「这样更干净」	大规模未审查变更	护栏 · 函数数预算
为小问题引入新依赖	「有现成库」	供应链攻击面扩大	护栏 · 依赖审批
触碰密钥与凭证文件	「测试需要」	凭证泄漏、环境破坏	护栏 · 冻结清单
静默调低日志级别	「消除告警噪音」	可观测性丧失	CI · 日志 diff 检查

表 3-2 禁止行为清单（反模式库，持续扩充）

3.3 冲突裁决与例外通道

铁律冲突时的优先序：安全底线（L8 知情披露）高于正确性（L5 红绿基线），正确性高于边界约束（L1、L3、L4、L6 与 L7），最后才是效率。典型冲突场景：问题本身位于冻结文件（如 CI 配置中的门禁缺陷）。此时唯一合法路径是：停止实施、产出方案单、经 GATE 审批获得对该文件的一次性修改授权——先解除限制，再动手修复，禁止先改后补票。

例外通道的设计原则：铁律本身不可关闭，可配置的只有一次性例外的审批门槛。每一次例外都必须留痕（触发铁律、审批人、理由、影响面），并进入反哺循环——同一铁律的例外申请频次过高，说明定级、预算或冻结清单的默认值需要校准，而不是放宽铁律。

第四章 问题分类、定级与准入

4.1 问题来源与分类

问题按来源分六类，按 IEEE 1044 的两维法归入「类型 × 原因」；安全类额外映射 CWE 弱点编号，组件类记录 CVE
与受影响组件路径。分类决定修复特征与流程参数，是后续定级、预算与审批矩阵的索引。

来源	典型问题	根因归属	修复特征
单元与集成测试	断言失败、异常抛出、用例超时	编码逻辑、接口契约	必须红绿基线；警惕测试本身有错
SAST 静态扫描	注入类、空解引用、资源泄漏、弱算法	编码缺陷	误报率高，必须配申诉通道
SCA 组件漏洞	依赖 CVE、许可冲突（奇安信开源卫士类）	第三方	按 4.3 决策序处置，变更必审
DAST 与 IAST	运行时注入、越权访问	编码与配置复合	需环境证据与复扫闭环
Lint 与规范	风格、圈复杂度、重复代码	编码习惯	批量小、可免审，注意范围控制
运行时告警	线上错误、性能回退	多因复合	常伴设计缺陷，警惕部分修复

表 4-1 问题来源与分类

4.2 严重度定级与处置时限

五级定级 S0 至 S4，安全类以 CVSS 为基准映射，冲突时就高不就低；功能类按业务影响判断。Agent 可建议定级，S0 至 S2
必须由人工确认后生效。定级同时决定预算档位（6.2）、审批级别（9.1）与处置时限（SLA）。

级别	判据	时限	默认审批
S0 灾难	生产数据损坏，或可被远程无交互利用且影响核心资产的漏洞（CVSS 9.0 以上）	24 小时	D3 双人
S1 严重	主干阻塞、核心功能不可用；CVSS 7.0 至 8.9	3 天	D2 事前确认
S2 高	非核心功能失效、有利用前置条件的漏洞；CVSS 4.0 至 6.9	7 天	D1 事后审计
S3 中	边缘场景缺陷、低危漏洞、lint 大类问题	14 天	D0 免审
S4 低	风格、文档性、提示性问题	择期	D0 免审

表 4-2 严重度定级、处置时限与默认审批

4.3 误报申诉、依赖修复与风险接受

误报申诉。SAST 类工具误报率高是行业常态（实践报告普遍在 20% 至 50%），不设申诉通道的直接后果是：Agent 把预算花在「修不存在的病」上，甚至为消除告警改坏本来正确的代码。申诉须附证据，三选一：污点流不可达证明（source 到 sink 无可达路径）、约束条件不可满足证明、上下文语义证明（代码意图与告警模式不匹配）。申诉由安全团队裁决；通过后标记 false-positive，并回写扫描器基线降噪——误报治理本身也是修复体系的闭环组成部分。

依赖类漏洞修复决策序。SCA 告警的处置按以下顺序择路，跳级须在方案单中说明理由：①补丁版本内升级；②兼容的次版本升级；③官方缓解配置；④等价组件替换；⑤缓解措施（WAF 规则、网关过滤、代码层规避）并登记风险。全链路遵守 GB/T 43698-2024 对供应链处置的要求，任何依赖变更一律触发 GATE 审批。

风险接受。S3 及以下、有缓解措施、书面登记并设 90 天到期复审的问题，可经审批后接受不修（won't fix）；S0 至 S2 不允许风险接受。风险接受不是 Agent 的选项，而是治理动作，Agent 只能发起申请，决定权在人。

4.4 修复准入检查

> **准入五查（P0 阶段门禁，任一不过即打回）**
>
> 一查可复现：有复现步骤、失败用例或扫描证据链接；二查未重复：与在办、已办修复单查重；三查范围明确：能定位到模块、文件或符号；四查判据明确：修复完成的判定方式可执行；五查来源可信：来自测试基线或受信扫描器。禁止在不满足五查的问题单上「猜着修」。

第五章 修复作业流程

5.1 流程总览

修复作业为七阶段状态机：准入、定位、方案、审批门、实施、验证、交付，外加强制复盘。流程的三个结构特征：定位阶段物理只读，把诊断权与修复权分离；审批门按 9.1 矩阵分流，低风险免审不阻塞；验证失败有界重试，连续失败强制升级人工（安灯）。全流程见图 5-1。



图 5-1 修复作业流程状态机（S 型主流程与异常路径）

5.2 阶段定义与门禁

阶段	执行者	输入	产出	硬性约束
P0 准入	Agent	问题单	准入检查记录	准入五查全过，任一不过即打回
P1 定位	Agent · 只读	问题单、代码库	根因单 RC	只读锁：禁止任何写操作；产出 5 Why 根因链与影响面初判
P2 方案	Agent	根因单 RC	方案单 FP	变更清单、预算、验证计划、回滚预案四要素齐备
GATE 审批	人工 · 按矩阵	方案单 FP	批准、修改或驳回	S0 至 S2、冻结触碰、依赖变更、测试修改必审
P3 实施	Agent · 沙箱写	方案单 FP	隔离分支原子提交	预算内、冻结外、白名单工具；达 90% 预算即告警收尾
P4 验证	CI + Agent	提交	验证单 VR	三道门全过；失败按 5.4 处置
P5 交付	Agent + 评审人	验证单、diff	已合并 PR	PR 强制字段完整，评审通过后合入
P6 复盘	Agent + 平台	全程轨迹	教训条目	复盘完成率 100%，不做复盘不算闭环

表 5-1 阶段定义、输入产出与硬性约束

5.3 红绿基线法

红绿基线是本规范对抗 reward hacking 的关键方法。红基线：修复之前，用最小复现用例证明问题存在（测试红、断言失败或扫描命中），证据先于修复代码归档。绿证据：修复之后，同一用例转绿，且三道验证门通过。其价值有三：一是防止修不存在的问题（与误报申诉联动）；二是锁定判据防篡改——红基线证据先于修复存在，事后改测试迁就代码会与红基线证据冲突，护栏可自动比对发现；三是为回归选择提供锚点。

安全类问题常无法构造运行时复现（需要特殊环境或攻击载荷），此时红绿等价证据为：原扫描器对修复前代码命中告警（红）、修复后复扫未命中且零新增（绿）。等价证据的替换必须在方案单中声明，防止借机绕过验证。

5.4 异常路径与安灯升级

验证失败实行有界重试：至多两轮，且回到 P1 必须提出新的根因假设——禁止无新假设的盲目重试，因为那是在用随机性对抗因果性。连续两轮失败触发**安灯升级**：Agent 停止一切修改，输出升级说明（已尝试方案、失败证据、怀疑方向、需要的资源），任务转人工接管。升级不是失败，而是把不确定性的处置权交还给有全局视图的人，这正是安灯机制的本义：停线优先于带病继续。

两类特殊出口。部分修复：若根因为设计缺陷、无法单点收敛，Agent 产出部分修复加遗留问题单，禁止自行扩大修复范围；遗留单按正常准入流程流转。方案变更：实施中发现方案前提不成立（如声明的调用方约定错误），回到 P2 重做方案单，禁止边改边设计。

第六章 行为约束与护栏机制

6.1 三层防线

把约束「集成到智能体」不等于写一段更强的提示词。提示词只影响意图，而意图层有天然失效模式：Agent 说服自己例外的理由永远比规则多。本规范采用三层独立防线，见图
6-1：提示词层管意图、运行时护栏管行为、CI 门禁管结果；三层互为冗余，任何一层单独失效，其余两层仍能兜底。全部关键约束必须同时落在防线二与防线三的机器规则里。



图 6-1 三层防线：意图层、行为层与结果层

6.2 变更预算

diff 预算按问题级别设定默认值（可按仓库配置收紧），计量四个维度：文件数、行数、函数数与依赖变更数。预算的理论依据是最小变更原理：回归概率随变更范围超线性增长，预算把修复压在回归概率最低的区间；同时根因修复几乎总是小 diff——大 diff 通常意味着在修症状或夹带私货。超预算不是死路：强制拆单（把修复分解为多个独立修复单）或升级审批。

级别	文件上限	行数上限	函数上限	依赖变更	超预算处置
S3、S4	3	±60	3	禁止	强制拆单
S2	5	±150	6	审批后至多一项	拆单或 GATE 审批
S0、S1	8	±300	10	审批后至多一项	GATE 审批并双人复核

表 6-1 diff 预算默认值（护栏达 90% 预算即告警，100% 停止写入）

6.3 冻结清单与权限阶梯

冻结清单是防错法的直接应用：不靠 Agent 「记得别碰」，而靠结构使触碰即拦截。含义澄清：冻结不是绝对不可改，而是「触碰即触发拦截并要求审批例外」；安全与凭证类资产则一律禁止。

类别	示例	处置
CI/CD 配置	.github/workflows、Jenkinsfile、.gitlab-ci.yml	触碰即拦截，修改走 GATE 例外
依赖清单	package.json、requirements.txt、pom.xml 等	变更必审，联动 4.3 决策序

类别	示例	处置
测试资产	既有测试文件、快照、测试基线	修改须经测试缺陷认定（双人）
安全与凭证	密钥、证书、鉴权配置、安全策略	一律禁止 Agent 触碰
基础设施与数据	IaC 脚本、数据库迁移脚本	触碰即拦截，必审
其他 Agent 产物	其他智能体会话产生的代码	禁止修改（防套娃），转人工协调

表 6-2 默认冻结清单

权限阶梯与流程阶段绑定：P1 定位阶段持只读权限（可读代码库、可执行测试、不可写）；P3 实施阶段持沙箱写权限（隔离分支、预算约束、工具白名单内）；合入写权限仅经 PR 通道，由 CI 与评审把门。Agent 永远不持有：主干直推、git push 强推、历史改写三类权限——这三项在工具层直接禁用，而非提示词约定。

6.4 三单结构化契约

三单是流程各阶段的强制产出：根因单 RC（P1）、方案单 FP（P2）、验证单 VR（P4），YAML 格式、schema 校验、不合 schema 规同阶段未完成。三单把本规范从「文档」变成「可校验的契约」：P4 门一自动执行 diff 对 FP 声明的比对，计划外文件出现即触发 L4 与 L8 违例处置。模板全文见附录 A，示例见下。

```
fix_plan:
issue: "VUL-2026-0911-003" # 问题单号
risk_level: S2
root_cause_ref: "RC-003"
changes: # 声明变更清单（L4 比对基准）
- file: "services/auth/token.py"
symbol: "TokenService.verify"
intent: "验签入口增加算法白名单，拒绝 alg=none"
budget: { files: 3, lines: 120, funcs: 4, deps: 0 }
frozen_avoided: [".github/workflows/*"]
verification:
red_baseline: "tests/regression/test_alg_none.py::test_rejects_none_alg"
regression_set: "impact-selected: 17 cases"
rescan: "SAST 复扫零新增"
rollback: "git revert 单提交即可；影响面仅 auth 模块"
approvals: [{ gate: D1, by: "sec-lead", at: "2026-09-11T10:20:00+08:00" }]
```

代码 6-1 修复方案单 FP 示例（YAML，schema 校验不合格即无效）

6.5 智能体集成方案

集成三件套。其一，守则注入：将铁律摘要注入系统提示或规则文件（AGENTS.md、.cursorrules 等），全文见附录 B；注入时绑定本仓库的预算与冻结清单参数。其二，运行时护栏：以 pre-commit 钩子或 Agent 工具层拦截器实现 diff
静态检查，规则配置示例见下。其三，平台对接：修复单生命周期事件映射 ATLAS
事件模型（9.2），GATE 审批映射 ATLAS 决策工单，复用既有通道而不另建回路。

```
guards:
- rule: FROZEN_TOUCH # 冻结清单守护
when: diff.touches(frozen_list)
action: block_and_escalate
- rule: TEST_TAMPERING # 测试篡改拦截（L3）
when: diff.matches("test/**") and not approved("test_defect")
action: block_and_report
- rule: ANTI_PATTERN # 禁改模式库（吞异常、注释代码等，L2）
when: diff.matches(anti_pattern_db)
action: block_and_suggest
- rule: DIFF_BUDGET # 预算计数器（6.2）
when: abs(diff) > 0.9 * budget(level)
action: warn_and_wind_down
- rule: PLAN_DEVIATION # 计划外变更披露（L4 / L8）
when: diff.files not in plan.changes
action: require_disclosure
```

代码 6-2 运行时护栏规则配置示例（pre-commit 拦截器消费）

第七章 验证与准出

7.1 三层验证门

验证由独立于 Agent 的 CI 裁决，三道门递进：门一静态一致性，防改坏了却不知道；门二定向验证，防问题没修好；门三回归选择，防修好了别处又坏了。每道门的失败对应明确的回退路径，失败计入安灯计数。

门	内容	失败处置
门一 静态一致性	编译通过；lint 零新增；护栏 diff 复查（预算、冻结、禁改模式）；三单一致性与 diff 对声明比对	回 P3 修正后重验
门二 定向验证	红基线用例转绿；变更模块相关单测全过	回 P1 重新定位，计一轮
门三 回归选择	回归选择集全过；安全项复扫零新增；副作用抽查	回 P1 并标记重点关注

表 7-1 三层验证门（GB/T 25000.51 证据要求：全部结果可归档、可复核）

7.2 回归测试选择

> **回归选择集的构造（安全回归测试选择的应用）**
> 选择集 = 覆盖变更行或变更函数调用闭包的测试 ∪ 依赖图反向可达模块的测试 ∪
> 本问题单历史上失败的测试 ∪ 安全关键路径测试。Safe RTS 理论保证：只要覆盖与依赖信息准确，该子集与全量回归等价（不漏检）；信息不足时回退全量回归。执行时长约束：选择集 P95 不超过 15 分钟，超时则分层——冒烟层必须全过，扩展层异步补充。

7.3 安全修复专项准出

安全类问题（SAST、SCA、DAST 来源）在通用准出之上叠加四条专项：一，复扫闭环——原扫描器对修复后代码复扫，原告警关闭且零新增高危命中；二，无新弱点——修复不得以引入另一个 CWE 弱点为代价（如修 SQL 注入时引入不安全的反序列化），由 SAST 增量比对确认；三，缓解有效——凡以缓解措施替代根治的，须附有效性证据（规则命中记录、渗透验证）；四，误杀检查——新增的校验、过滤逻辑不得破坏合法业务流，以核心链路回归佐证。

7.4 准出检查单与提交规范

序	准出条件	校验方式
1	红基线与绿证据已归档并可追溯	自动 · 验证单字段
2	三道验证门全部通过且记录完整	自动 · CI 流水线
3	实际 diff 落在方案单声明范围内	自动 · 门一比对
4	diff 预算未超限	自动 · 预算计数器
5	冻结清单零触碰或已有审批例外	自动 · 护栏记录
6	原子提交、可独立 revert	自动 · 提交检查
7	PR 强制字段完整：问题单号、根因、影响面、证据、回滚方式	自动 · PR 模板校验
8	安全项复扫通过且无新增命中	自动 · 扫描器
9	复盘完成、教训条目入库	人工 · 平台确认
10	全程留痕事件按 ATLAS 上报完整	自动 · 平台对账

表 7-2 准出检查单（DoD），第 9 条为唯一人工项

提交规范：提交信息格式为 fix(范围): [问题单号]
样式加一句话根因描述，正文包含根因概述、影响面与验证证据引用；一个 PR 只承载一个修复单，混合承载直接驳回。PR 描述即验证单的人类可读投影，两处数据必须一致，由模板校验保证。

第八章 度量与持续改进

8.1 核心度量

指标	定义	目标
新缺陷引入率	合入后 30 天内发现新缺陷的修复单占比（北极星指标）	低于 5%
一次通过率	P4 三道门一次通过占比	不低于 70%（试点 60%）
发散指数	触发预算或范围拦截的修复单占比	低于 10%
测试篡改成功数	未授权测试修改进入主干的数目	0（红线）
安灯升级率	触发安灯升级的修复单占比	10% 至 25% 区间
SLA 达成率	在处置时限内完成的修复单占比	不低于 90%
误报申诉周期	申诉提交到裁决的 P50 时长	不超过 3 天
复盘完成率	完成 P6 复盘的修复单占比	100%

表 8-1 核心度量与目标值

两项读数校准说明。安灯升级率健康区间为 10% 至
25%：过低说明验证门太松或任务难度错配不足，过高说明 Agent 能力与任务难度整体错配，应调整任务分派而非放宽验证。发散指数与拦截数是互补的：发散指数度量「没拦住的」，护栏拦截数度量「拦住的」，两者共同刻画真实发散水平，看板须并排呈现。

8.2 教训反哺循环

P6 复盘产出三类教训条目：避错规则（进提示词与技能库）、防错规则（进护栏与 CI
门禁，结构性防错）、判例（进修复案例库供检索）。条目沿四个回路回流，见图
8-1：快回路实时、中回路周度、慢回路月度、知识回路持续。这也是与自进化体系（Reflexion 式避错记忆、技能库）的对接面：修复单的「失败—复盘—规则化」是最高质量的学习信号源——每个信号都有完整证据链与人工裁决背书，无需二次标注。



图 8-1 教训反哺循环：四回路与自进化体系对接

8.3 成熟度模型

级别	特征	晋级判据
M1 无约束	Agent 直接改代码，人工事后兜底	铁律注入与护栏 MVP 上线
M2 规则约束	三层防线运行：预算、冻结、红绿基线门禁	发散指数低于 20%，KPI 看板上线
M3 度量反馈	全量度量、安灯自动化、误报申诉运行	一次通过率不低于 60%，反哺四通道自动化
M4 知识反哺	判例库与规则回流运行，修复前自动检索判例	新缺陷引入率低于 5%
M5 自适应治理	预算与审批阈值按项目风险画像自调，规范自演化评审	持续运营，年度修订

表 8-2 修复治理成熟度模型

第九章 治理协同与实施路线

9.1 角色与审批矩阵

审批矩阵是 ATLAS D 级分级（D0 免审、D1 事后审计、D2 事前确认、D3 双人审批）在修复作业域的实例化；与本规范不一致时，取两者中更严格者。设计基调延续 ATLAS 的最小打断原则：把人工注意力集中在真正的高危动作上，其余交给机器与事后审计。

级别	触发条件	说明
D0 免审	S4 全部；S3 且预算内、无冻结触碰、无依赖变更	直接执行，事后可查
D1 事后审计	S3 其余情形；S2 预算内且无冻结触碰与测试修改	合入后抽检，24 小时内出审计结论

级别	触发条件	说明
D2 事前确认	S1 与 S0 全部；依赖清单任何变更；测试缺陷认定；超预算拆单方案；部分修复与风险接受申请	阻塞等待人工，映射 ATLAS 决策工单
D3 双人审批	冻结文件永久解除；S0 生产级热修；安全策略变更	双人在场，映射 ATLAS 双签工单

表 9-1 修复作业审批矩阵（ATLAS D 级实例化）

角色职责（RACI 精简版）：修复执行 Agent 为 R（执行）；开发评审人对修复质量负 A（最终批准）；安全团队对安全类定级、误报裁决与专项准出负 C（被咨询）；平台管理员对护栏配置、冻结清单与预算默认值负 A；QA 对度量看板与复盘质量负 I（知会）。

9.2 留痕与审计对接

修复单全生命周期事件按 ATLAS 协议上报，自定义事件以 x- 前缀命名空间隔离；三单、红绿基线证据与门禁日志作为呈报工件挂载，留存周期与代码库同寿命，审批记录按 ATLAS 要求留存三年。关键映射如下。

作业事件	ATLAS 易射	层级
x-fix.intake 准入通过或打回	task 事件	L1
x-fix.rootcause 根因单提交	artifact 呈报事件	L1
x-fix.plan 方案单提交	artifact 呈报事件	L1
decision.required 审批门触发	复用 ATLAS 冬策工单	决策回路
x-fix.commit 原子提交	变更呈报 ChangeReport + diff 工件	L2
x-fix.gate 门禁结果	验证证据事件	L2
x-fix.escalate 安灯升级	critical 事件，即时告警	L1
x-fix.retrospective 复盘与教训	知识回流事件	L1

表 9-2 修复作业事件与 ATLAS 协议映射（x- 前缀为规范附录 A 扩展位）

9.3 实施路线与验收

阶段	范围与动作	退出判据
一期 试点（4 到 6 周）	单仓库；铁律注入、护栏 MVP（diff 检查、预算计数、红绿基线门禁）；S3、S4 先行	一次通过率不低于 60%；测试篡改拦截率 100%
二期 推广（一个季度）	多仓库；审批矩阵接入 ATLAS；KPI 看板；误报申诉流程运行	新缺陷引入率低于 8%；SLA 达成率不低于 85%
三期 优化（持续）	反哺四通道运行；判例库建设；成熟度 M3 向 M4 爬坡	新缺陷引入率低于 5%；安灯升级率落入健康区间

表 9-3 三阶段实施路线

序	验收项	通过标准
V1	铁律注入生效抽查	注入 Agent 的守则与本规范一致，版本可追溯
V2	冻结文件触碰拦截	构造触碰用例，护栏 100% 拦截并留痕
V3	预算超限拦截	构造超预算 diff，达 90% 告警、100% 停写
V4	红基线缺失拦截	无红基线申报完成，验证单校验驳回
V5	测试篡改拦截	构造测试修改，未经认定即拦截
V6	三单 schema 校验	不合 schema 的三单被判定阶段未完成
V7	安灯升级演练	连续两轮失败自动升级，升级说明完整
V8	反哺规则生效	复盘教训可生成护栏规则并在下一单生效

表 9-4 规范落地验收清单

本规范自发布日起施行。铁律、定级、预算与审批矩阵的修订走慢回路（8.2），版本化发布并随平台归档；各仓库可在不突破本规范底线的前提下叠加更严格的本地配置。

附录 A 修复作业三单模板

三单为流程强制产出的机器可校验契约，schema 要点：字段齐备、枚举合法、引用互链（RC、FP、VR 三者通过编号互链）。以下为完整模板。

```
root_cause: # 根因单 RC（P1 产出）
issue: "VUL-2026-0911-003"
symptom: "SAST 报告 JWT 验签接受 alg=none（CWE-347）"
chain: # 5 Why 根因链
- "为何告警：verify() 未校验 alg 头即验签"
- "为何未校验：复用了 legacy 示例代码"
- "为何未被拦截：无针对 JWT 算法的 lint 规则"
root_cause: "验签入口缺少算法白名单校验"
evidence: "扫描报告 #8821；复现用例 test_rejects_none_alg（红）"
impact_scope: ["services/auth/**", "网关 token 校验链路"]
confidence: high
```

代码 A-1 根因单 RC 模板

```
verify_report: # 验证单 VR（P4 产出）
plan_ref: "FP-003"
gates:
gate1_static: { result: pass, lint_new: 0, budget_used: "62%" }
gate2_targeted: { result: pass, red_case: "red-to-green", related: "23/23" }
gate3_regression: { result: pass, selected: "17/17", rescan_new: 0 }
```

```
diff_vs_plan: { planned_files: 2, actual_files: 2, deviation: none }
residual_risks: []
lessons: # 反哺条目（P6 输入）
- "签名算法应集中白名单管理"
- "建议新增 lint 规则：拦截 alg=none 硬编码"
```

代码 A-2 验证单 VR 模板

附录 B 智能体守则注入片段

以下片段注入系统提示或 AGENTS.md
等规则文件，花括号参数由平台按仓库与定级自动填充；注入内容必须由护栏与 CI
兜底执行，不得作为唯一防线（6.1）。

```
# AEGIS V1.0 修复作业守则（注入系统提示 / AGENTS.md）
1. 你只处理当前问题单 {{issue_id}}；禁止重构、重命名、格式化任何无关代码。
2. 未取得红基线（复现证据）前，禁止写第一行修复代码。
3. 测试文件只读：修改测试预期须提交《测试缺陷认定单》并等待批准。
4. 冻结清单文件禁止触碰；命中即停止并上报，不得绕行。
5. 变更预算：文件数 {{max_files}} 以内、行数 ±{{max_lines}} 以内；达 90% 立即收尾。
6. 每阶段产出对应三单（RC / FP / VR），不合 schema 视为阶段未完成。
7. 同一问题连续 2 轮验证失败：停止尝试，输出升级说明转人工。
8. 任何超范围修改、不确定性、新发现的问题：即时披露，禁止静默处理。
```

代码 B-1 守则注入片段（可裁剪，不得删减第 2、3、4、8 条）

附录 C 术语表

术语	定义
修复单	最小修复作业单元，一个修复单对应一个已确认的问题
红绿基线	修复前复现失败的证据（红）与修复后通过的证明（绿）的组合
diff 预算	修复单允许的最大变更规模，按文件数、行数、函数数与依赖数计量
冻结清单	默认禁止 Agent 修改的资产清单，触碰即触发拦截或审批例外
三单	根因单 RC、方案单 FP、验证单 VR 的合称，流程各阶段的强制结构化产出
回归选择集	基于变更影响分析选出的回归测试子集，理论上与全量回归等价
安灯升级	连续验证失败后自动停止并转人工的机制，源自丰田安灯
发散指数	触发预算或范围拦截的修复单占比，发散程度的核心度量
测试缺陷认定	声明测试本身有误并请求修改测试的正式流程，双人审批
风险接受	经登记与审批对问题不予修复的正式决定，带 90 天到期复审

表 C-1 术语与定义